

TMJ Clinic CRM — Backend Flow Specification

1. Authentication Module

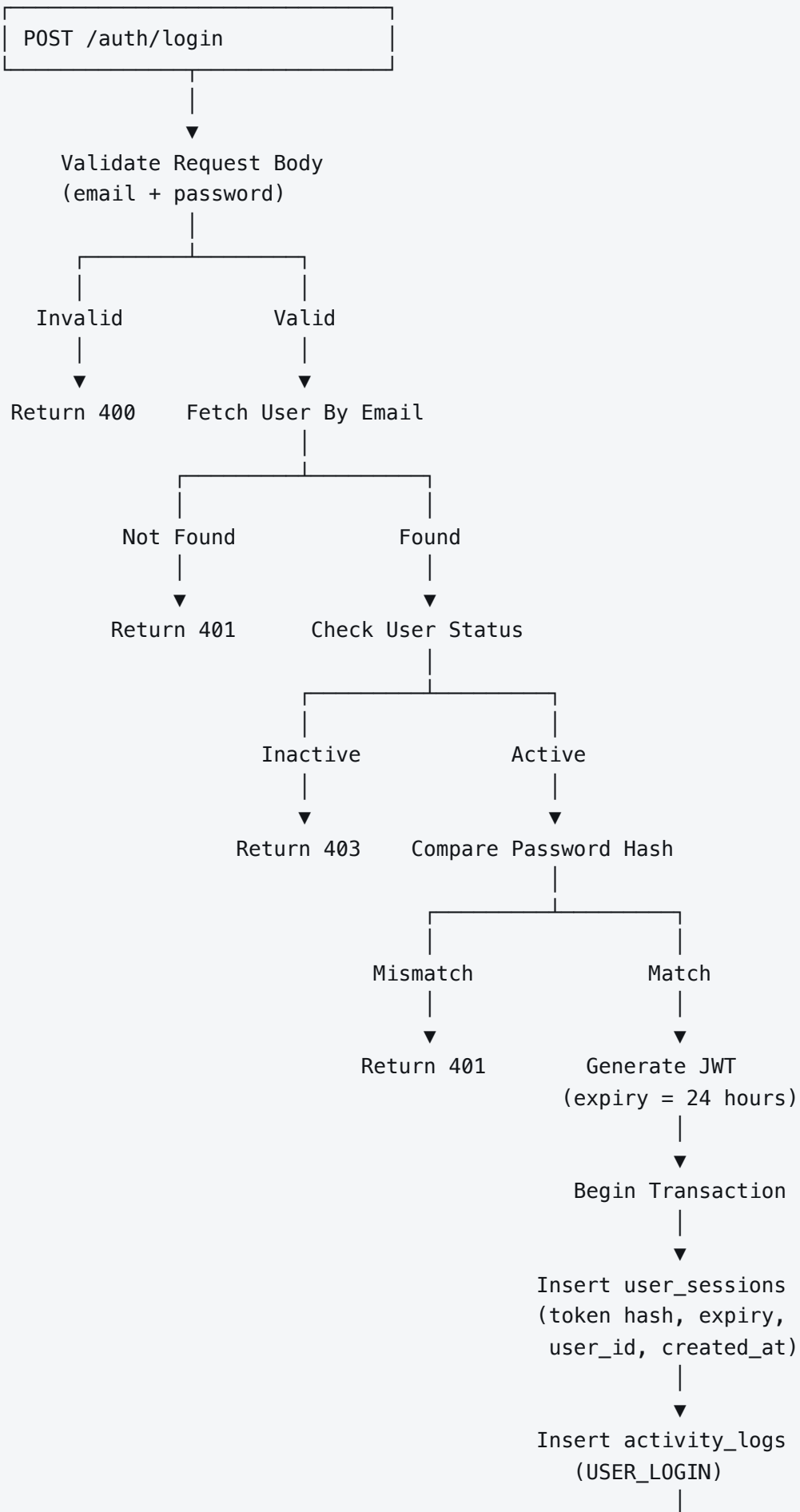
1.1 LOGIN

ENDPOINT

POST /api/v1/auth/login

PURPOSE

- Validate credentials
- Generate JWT (24h validity)
- Create session
- Return user profile + role for dashboard redirection



▼
Commit
|
▼
Return Success
{ token, user: { id,
name, role, expiry } }

TABLES AFFECTED

1. users (SELECT)
– Fetch By Email
2. user_sessions (INSERT)
– New Session Record
3. activity_logs (INSERT)
– USER_LOGIN

ERROR RESPONSES

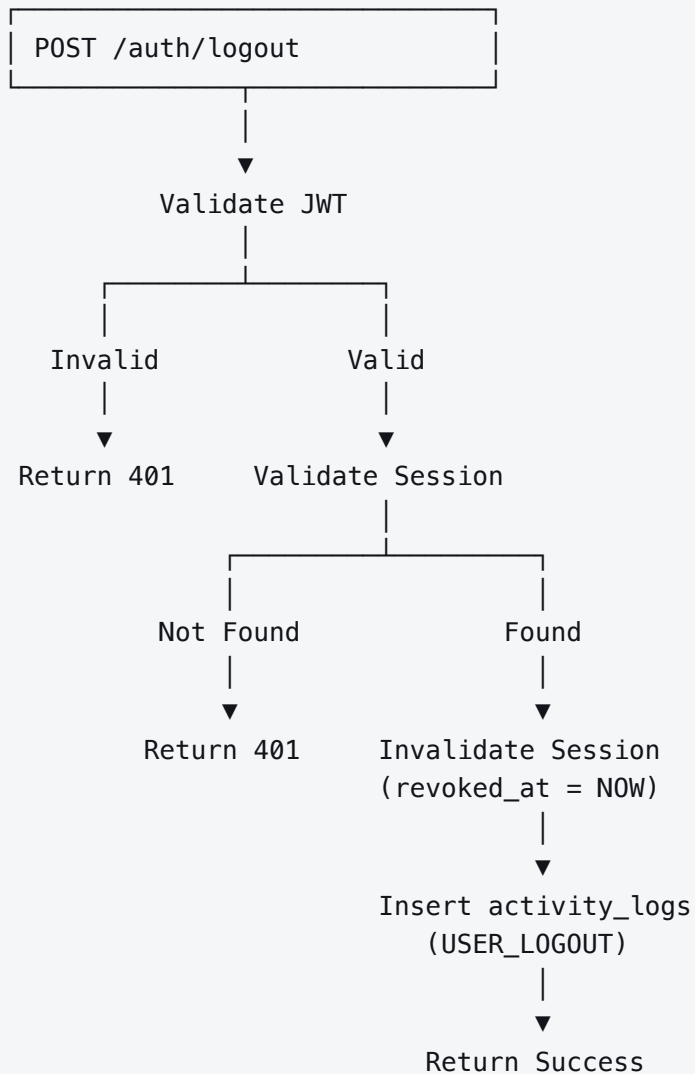
400 Missing / invalid email or password format
401 Invalid email or password
(user not found OR wrong password)
403 Account inactive
500 Server / database failure

Note: Return the same message for "user not found" and "wrong password" → Invalid email or password. Please try again. (prevents user enumeration)

1.2 LOGOUT

ENDPOINT

POST /api/v1/auth/logout



TABLES AFFECTED

1. `user_sessions` (SELECT)
2. `user_sessions` (UPDATE)
 - `revoked_at`
3. `activity_logs` (INSERT)

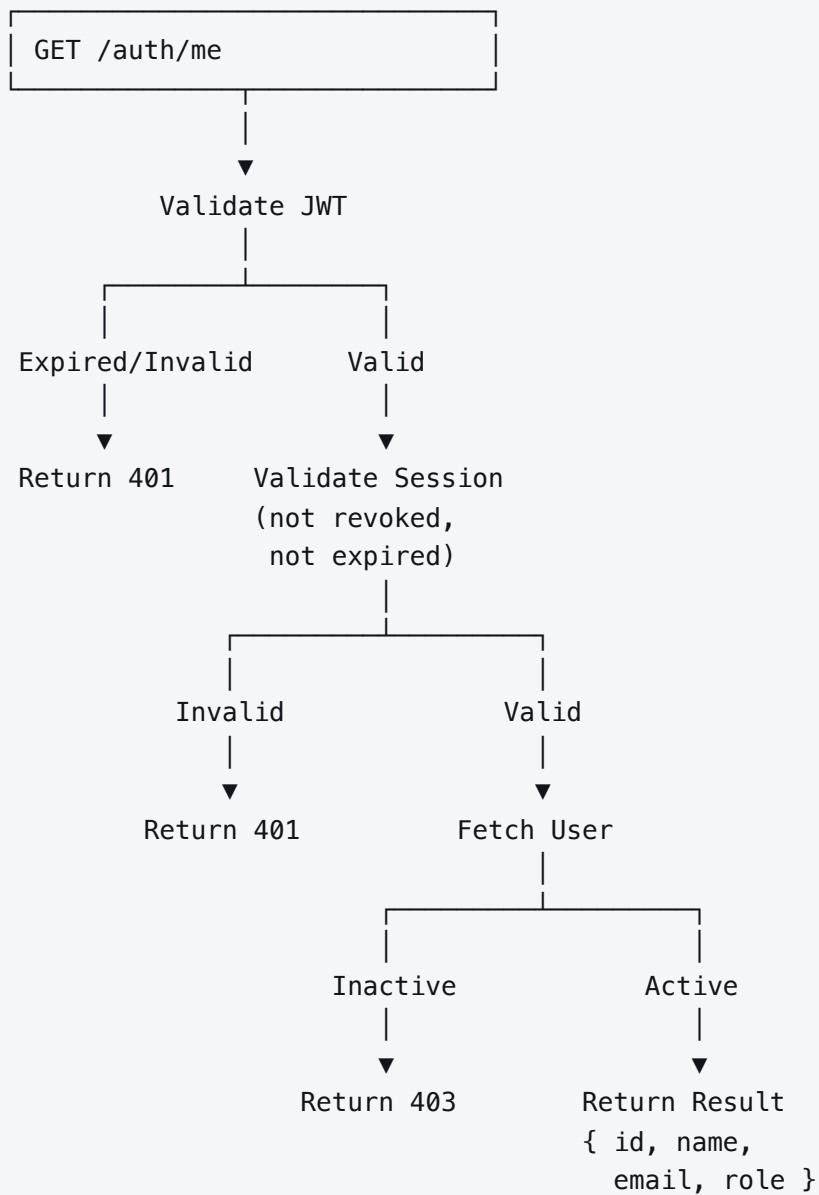
1.3 GET CURRENT USER (Session Restore)

ENDPOINT

GET `/api/v1/auth/me`

PURPOSE

- Restore session on browser refresh / new tab
- Frontend calls this on app bootstrap when `crm_token` exists in localStorage

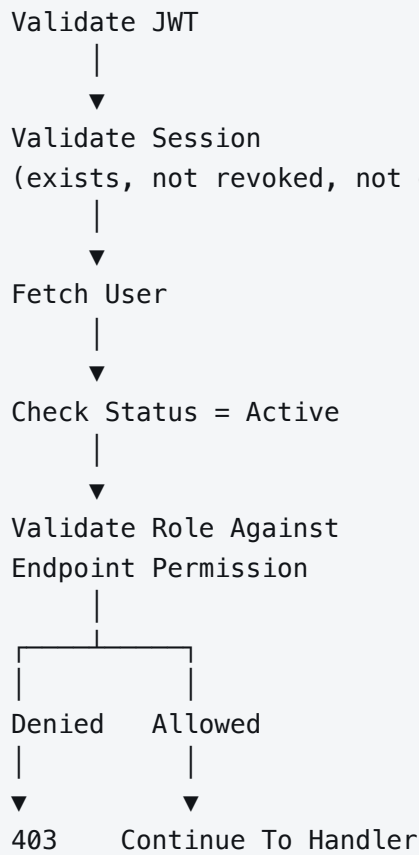


TABLES AFFECTED

1. `user_sessions` (SELECT)
2. `users` (SELECT)

1.4 RBAC / Route Guard (applies to ALL protected endpoints)

Every protected endpoint runs this shared guard chain before its own logic:



ROLE → DASHBOARD MAPPING (FRONTEND REDIRECT AFTER LOGIN)

ADMIN	→ /dashboard/admin
MANAGER	→ /dashboard/manager
SALES	→ /dashboard/sales
RECEPTIONIST	→ /dashboard/reception
DOCTOR	→ /dashboard/doctor

SESSION RULES

- JWT validity: 24 hours
- Expired token → 401 → frontend clears
localStorage → redirect /login
- Revoked session → 401
- Cross-role dashboard → 403 → frontend redirects
to own dashboard
- Storage keys → crm_token, crm_user
(localStorage)

2. Lead Management Module — Lead Creation

2.1 CREATE LEAD

ENDPOINT

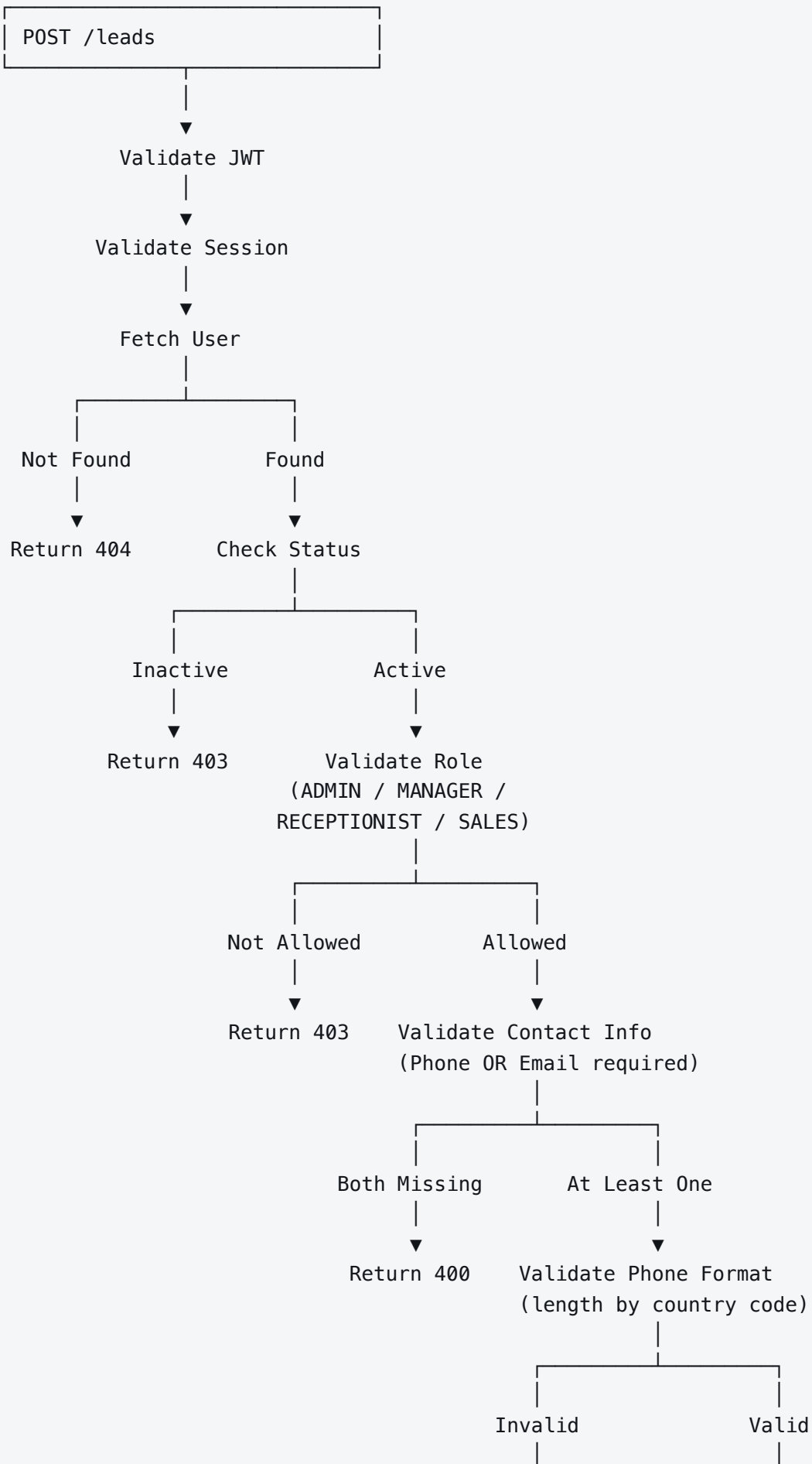
POST /api/v1/leads

PURPOSE

- Capture new patient inquiry with minimal mandatory info
- Default stage → NEW_LEAD
- Default status → lead_added
- Generate initial activity log
- Push realtime event so lead appears instantly in lead list

ALLOWED ROLES

ADMIN / MANAGER / RECEPTIONIST / SALES



Return 400

Validate Email
Format

Invalid

Valid

Return 400

(A)

Continued from (A):

(A)

Begin Transaction

Insert Lead

current_stage = NEW_LEAD
current_status = lead_added
created_by = currentUserId

Insert lead_status_history
(NEW_LEAD / lead_added)

Insert activity_logs
(LEAD_CREATED)

Commit

Emit Realtime Event
(lead.created)

Return Success
(201 + lead object)

TABLES AFFECTED

1. user_sessions (SELECT)
2. users (SELECT)
3. leads (INSERT)
 - current_stage = NEW_LEAD
 - current_status = lead_added
 - created_by
4. lead_status_history (INSERT)
 - Initial Stage/Status Entry
5. activity_logs (INSERT)
 - LEAD_CREATED

VALIDATION RULES

- | | |
|--------------------|--|
| Phone OR Email | → At least one mandatory |
| Phone | → Length validated based on
selected country code |
| Email | → Valid format, max 255 chars, trimmed |
| Name (if provided) | → Trimmed |

ERROR RESPONSES

- 400 No phone AND no email provided
- 400 Invalid phone length for selected country
- 400 Invalid email format
- 401 Missing / expired JWT
- 403 Inactive user OR role not permitted
- 404 User not found
- 500 Database failure (transaction rolled back –
no partial lead)

EDGE CASE HANDLING

Duplicate submit (double-click)

- Frontend disables button; backend may use idempotency key / dedupe window

Database timeout

- Transaction rollback, return 500, no orphan history/log rows

Realtime channel disconnected

- Lead still created; list refreshes on next fetch (realtime is best-effort)

Modal closed without saving

- No API call made

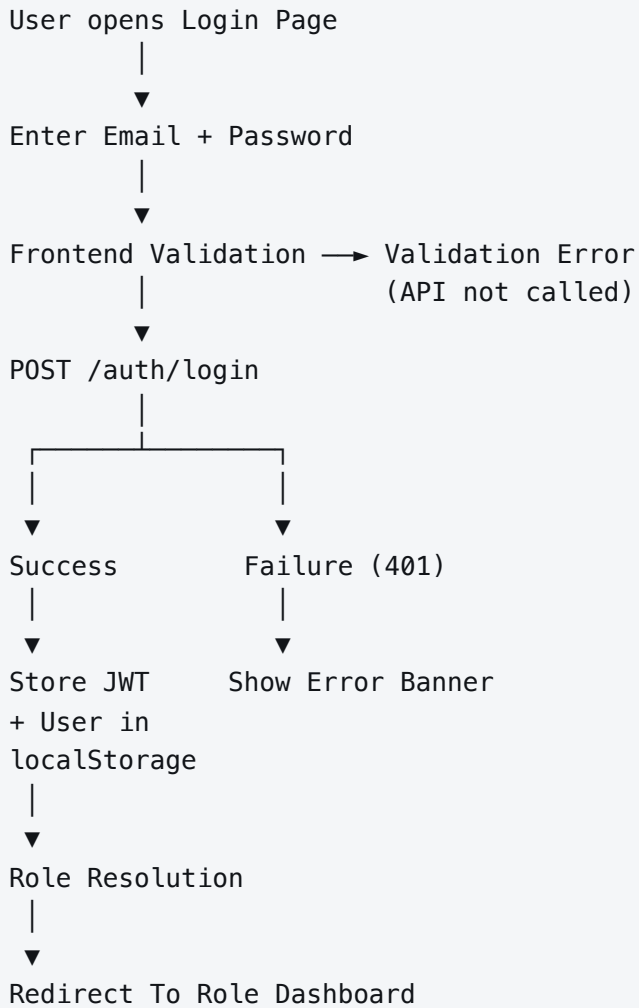
Slow network

- Frontend shows loading state, prevents re-submission
-

System Summary Flow

LOGIN

=====



CREATE LEAD

=====

